

Tutase161452 10%

1) Bảo mật cơ bản, Port Security

- **5 thực hành bảo mật cơ bản:**
 1. Thay đổi thông tin đăng nhập (username/password) mặc định.
 2. Tắt các dịch vụ không cần thiết (như Telnet, HTTP) và sử dụng các dịch vụ an toàn (như SSH, HTTPS).
 3. Cập nhật firmware/IOS thường xuyên.
 4. Vô hiệu hóa (shutdown) tất cả các cổng không sử dụng.
 5. Sử dụng Port Security và DHCP Snooping.
 - **Tại sao tắt cổng không sử dụng:** Để ngăn chặn truy cập trái phép. Nếu một cổng đang "mở" (up), bất kỳ ai cũng có thể cắm thiết bị vào và có khả năng truy cập mạng.
 - **Cơ chế Port Security:** Giới hạn truy cập vào một cổng switch dựa trên địa chỉ MAC. Nó kiểm soát số lượng MAC được phép và/hoặc chỉ định *những* MAC cụ thể nào được phép.
 - **Thiết lập giới hạn MAC:** Sử dụng lệnh `switchport port-security maximum [số_lượng]` trên interface. (Ví dụ: `maximum 1` chỉ cho phép 1 MAC).
-

2) Hoạt động của Switch

- **Quá trình chuyển tiếp frame:**
 1. Switch nhận một frame trên một cổng.
 2. Switch đọc địa chỉ MAC *nguồn* và ghi nó vào bảng MAC (nếu chưa có) cùng với cổng nhận.
 3. Switch đọc địa chỉ MAC *đích*.
 4. Nó tra cứu MAC đích trong bảng MAC:
 - Nếu tìm thấy, switch **forwarding** (chuyển tiếp) frame đó *chỉ* ra cổng tương ứng.
 - Nếu không tìm thấy (hoặc là địa chỉ broadcast/multicast), switch **flooding** (lụt) frame ra tất cả các cổng khác (trừ cổng nguồn).
 - **Phân biệt:**
 - **Forwarding (Chuyển tiếp):** Gửi frame đến một cổng cụ thể khi biết MAC đích.
 - **Flooding (Lũ lụt):** Gửi frame ra tất cả các cổng (trừ cổng nguồn) khi không biết MAC đích.
 - **Filtering (Lọc):** Hủy (drop) frame khi cổng đích *chính là* cổng nguồn (không cần chuyển tiếp ngược lại).
-

3) VLAN và 802.1Q

- **Lợi ích của VLAN:** VLAN (Virtual LAN) phân đoạn một mạng vật lý thành nhiều mạng logic (broadcast domain) riêng biệt. Lợi ích:

- **Tăng bảo mật:** Các thiết bị trên các VLAN khác nhau không thể giao tiếp trực tiếp (cần router).
 - **Giảm lưu lượng quảng bá (broadcast):** Broadcast chỉ lan truyền trong nội bộ VLAN, giúp tăng hiệu suất mạng.
 - **Tăng tính linh hoạt:** Gom nhóm các thiết bị theo logic (ví dụ: Kế toán, Kỹ thuật) thay vì vị trí vật lý.
 - **Access Port vs. Trunk Port:**
 - **Access Port:** Chỉ thuộc về *một* VLAN duy nhất. Thường dùng để kết nối với các thiết bị đầu cuối (PC, máy in).
 - **Trunk Port:** Có thể mang lưu lượng của *nhiều* VLAN cùng lúc. Thường dùng để kết nối giữa các switch hoặc giữa switch và router.
 - **Hoạt động của 802.1Q (Dot1Q):** Là một tiêu chuẩn *VLAN tagging*. Khi một frame đi qua trunk port, 802.1Q chèn một "tag" (thẻ) 4 byte vào header của frame. Thẻ này chứa thông tin ID của VLAN, giúp switch ở đầu bên kia biết frame này thuộc về VLAN nào.
-

4) Spanning Tree Protocol (STP)

- **Mục đích của STP:** Ngăn chặn hiện tượng lặp vòng (loop) ở Layer 2 trong các mạng có đường kết nối dự phòng. Loop gây ra bão quảng bá (broadcast storm), làm sập mạng. STP thực hiện điều này bằng cách *khóa (block)* một số cổng dự phòng một cách logic.
 - **Các trạng thái của cổng STP:**
 - **Blocking (Khóa):** Chỉ nghe BPDU (gói tin STP), không forward data. Đây là trạng thái ngăn chặn loop.
 - **Listening (Lắng nghe):** Bắt đầu tham gia STP, gửi/nhận BPDU, chuẩn bị chuyển sang forwarding.
 - **Learning (Học):** Học địa chỉ MAC (xây dựng bảng MAC) nhưng chưa forward data.
 - **Forwarding (Chuyển tiếp):** Hoạt động bình thường, gửi/nhận data và BPDU.
 - **Disabled (Tắt):** Cổng bị tắt (shutdown) bởi quản trị viên.
 - **Nếu có loop:** Một frame broadcast sẽ bị chuyển tiếp lòng vòng vô hạn giữa các switch. Mỗi vòng lặp, frame này lại được nhân bản, tạo ra một **bão quảng bá (broadcast storm)**, làm tiêu tốn toàn bộ băng thông và CPU của switch, khiến mạng bị sập hoàn toàn.
-

5) DHCP Relay Agent

- **DHCP Relay Agent là gì:** Là một thiết bị (thường là router) nằm giữa client và DHCP server khi chúng không cùng một broadcast domain (subnet). Vì DHCP Discover là gói tin broadcast (không đi qua router), relay agent sẽ "bắt" gói tin này và chuyển nó thành gói tin unicast để gửi đến DHCP server ở subnet khác.
- **Vai trò của IP helper-address:** Đây là lệnh cấu hình trên interface router (phía client) để chỉ định địa chỉ IP của DHCP server. Nó cho router biết *nơi* để chuyển tiếp (relay) các yêu cầu DHCP.
- **Quá trình DORA (Discover, Offer, Request, ACK):**

1. **Discover:** Client (Broadcast) "Có ai cấp IP cho tôi không?"
 2. **Offer:** DHCP Server (Unicast) "Tôi có IP [192.168.1.10] này, bạn muốn dùng không?"
 3. **Request:** Client (Broadcast) "OK, tôi xin nhận IP [192.168.1.10] từ server [tên_server]."
 4. **ACK (Acknowledge):** DHCP Server (Unicast) "Xác nhận, IP [192.168.1.10] là của bạn."
-

6) IPv6 (SLAAC, DHCPv6, Link-Local)

- **So sánh:**
 - **SLAAC (Stateless Address Autoconfiguration):** Client tự động tạo địa chỉ IPv6 (phần host) dựa trên tiền tố (prefix) nhận từ router (RA message) và địa chỉ MAC (sử dụng EUI-64). Không cần server, không quản lý trạng thái.
 - **DHCPv6 (Stateful):** Tương tự DHCPv4. Server quản lý, cấp phát và theo dõi địa chỉ IPv6 đầy đủ cùng các thông tin khác (DNS, domain).
 - **Manual Configuration:** Quản trị viên tự nhập thủ công toàn bộ địa chỉ IPv6 và gateway.
- **Địa chỉ Link-Local (FE80::):** Là địa chỉ tự động gán cho mọi interface IPv6. Nó *chỉ* được sử dụng để giao tiếp trong phạm vi *cùng một liên kết (segment) mạng*. Nó không thể định tuyến. Các giao thức (như Neighbor Discovery) dùng địa chỉ này để tìm router và các láng giềng.
- **Ví dụ cấu hình IPv6 DHCPv6 Server (Cisco IOS):**

Cisco CLI

```
ipv6 dhcp pool VLAN10_POOL
address prefix 2001:DB8:ACAD:10::/64
dns-server 2001:DB8:ACAD::1
domain-name example.com
!
interface G0/1
ipv6 address 2001:DB8:ACAD:10::1/64
ipv6 dhcp server VLAN10_POOL
```

7) Tấn công LAN

- **3 kiểu tấn công phổ biến:**
 1. **MAC Flooding (MAC Table Overflow):** Kẻ tấn công gửi hàng ngàn frame với MAC nguồn giả. Switch bị đầy bảng MAC, chuyển sang chế độ "fail-open" (hoạt động như hub), gửi (flood) tất cả traffic ra mọi cổng, cho phép kẻ tấn công "nghe lén".
 2. **DHCP Starvation:** Kẻ tấn công gửi hàng ngàn yêu cầu DHCP (Discover/Request) với MAC giả để "thuê" hết tất cả IP có sẵn trong pool, khiến các client hợp lệ không thể nhận được IP.
 3. **ARP Spoofing (Man-in-the-Middle):** Kẻ tấn công gửi gói tin ARP giả mạo, lừa client (hoặc gateway) rằng MAC của kẻ tấn công tương ứng với IP của gateway (hoặc client).
- **Hậu quả ARP Spoofing:** Cho phép tấn công Man-in-the-Middle (MITM). Kẻ tấn công đứng giữa client và gateway, có thể đọc, sửa đổi hoặc chặn toàn bộ lưu lượng truy cập (ví dụ: đánh cắp mật

khẩu).

- **Cấu hình Port Security (Giới hạn 2 MAC):**

Cisco CLI

```
interface FastEthernet0/1
switchport mode access
switchport port-security
switchport port-security maximum 2
switchport port-security violation restrict
```

- **Tại sao cần BPDU Guard:** Bật trên các access port (cổng cắm PC, máy in). Nếu cổng này nhận được gói tin BPDU (gói tin của STP, chỉ do switch gửi), BPDU Guard sẽ lập tức đưa cổng vào trạng thái `err-disabled`. Điều này ngăn chặn người dùng cắm nhầm một switch vào mạng, gây xáo trộn STP hoặc tạo loop.
- **Phát hiện/Ngăn chặn DHCP Rogue Server:** Sử dụng tính năng **DHCP Snooping**. Switch được cấu hình để "tin tưởng" (trust) cổng kết nối đến DHCP server hợp lệ. Nó sẽ "không tin tưởng" (untrust) các cổng client khác. Nếu một server giả mạo (rogue) cắm vào cổng untrusted và cố gắng gửi DHCP Offer, switch sẽ chặn gói tin đó.

8) Wi-Fi (WLAN)

- **Phân biệt SSID, BSSID, ESSID:**
 - **SSID (Service Set Identifier):** Tên của mạng Wi-Fi mà bạn nhìn thấy (ví dụ: "MyHomeWiFi", "CoffeeShop").
 - **BSSID (Basic Service Set Identifier):** Địa chỉ MAC của Access Point (AP). Mỗi AP (hoặc mỗi radio trên AP) có một BSSID duy nhất.
 - **ESSID (Extended Service Set Identifier):** Về cơ bản, là SSID khi được sử dụng trong một mạng có *nhiều* AP cùng phát một SSID (hỗ trợ roaming). Trong thực tế, thuật ngữ SSID và ESSID thường được dùng thay thế cho nhau.
- **3 Tiêu chuẩn 802.11 phổ biến:**
 - **802.11n (Wi-Fi 4):** Lên đến 600 Mbps (sử dụng 2.4 GHz và 5 GHz).
 - **802.11ac (Wi-Fi 5):** Lên đến ~1.3 Gbps hoặc cao hơn (chỉ 5 GHz).
 - **802.11ax (Wi-Fi 6):** Lên đến ~10 Gbps (sử dụng 2.4 GHz và 5 GHz), tập trung vào hiệu suất cao trong môi trường đông đúc.
- **Infrastructure vs. Ad-hoc:**
 - **Infrastructure Mode:** Chế độ phổ biến. Các client (PC, điện thoại) kết nối với một **Access Point (AP)** trung tâm. AP quản lý kết nối và liên kết mạng Wi-Fi với mạng có dây.
 - **Ad-hoc Mode (Peer-to-Peer):** Các client kết nối *trực tiếp* với nhau mà *không* cần AP. (Ví dụ: hai laptop kết nối trực tiếp để chia sẻ file).

9) Mô hình WLAN (WLC)

- **Autonomous AP vs. Centralized (WLC):**

- **Autonomous AP (Độc lập / Fat AP):** Mỗi AP là một thiết bị thông minh, được cấu hình và quản lý độc lập. Mỗi AP xử lý toàn bộ (xác thực, mã hóa, roaming). Khó quản lý khi số lượng lớn.
- **Centralized (WLC - Wireless LAN Controller / Lightweight AP):** Sử dụng một WLC trung tâm để quản lý *tất cả* các AP (gọi là Lightweight AP - LAP). Cấu hình, cập nhật, bảo mật được đẩy từ WLC xuống AP. Dễ quản lý, giám sát và roaming tốt hơn.

- **Vai trò của CAPWAP:** (Control and Provisioning of Wireless Access Points). Đây là giao thức đường hầm (tunnel) mà Lightweight AP (LAP) sử dụng để giao tiếp với WLC. Nó đóng gói tất cả lưu lượng *quản lý* (control) và *dữ liệu* (data) của client giữa AP và WLC.

- **Sơ đồ mô hình WLC (Mô tả):**

- Clients (Laptop, Điện thoại) <-(Wi-Fi)-> **Access Point (LAP)**
- **Access Point (LAP)** <-(Ethernet)-> **Switch (Layer 2)**
- **Switch (Layer 2)** <-(Ethernet)-> **WLC (Controller)**
- **WLC (Controller)** <-(Ethernet)-> **Router/Core Switch (Layer 3)** -> Internet/Servers.

10) Bảng định tuyến (Routing Table)

- **Router sử dụng Bảng định tuyến:**

1. Router nhận một gói tin (packet).
2. Router kiểm tra địa chỉ IP đích của gói tin.
3. Router tra cứu địa chỉ IP đích này trong bảng định tuyến (routing table).
4. Router tìm kiếm "**Longest Prefix Match**" (mạng con khớp chính xác nhất/dài nhất).
5. Khi tìm thấy route phù hợp, router sẽ gửi gói tin đến địa chỉ **Next-Hop** (router kế tiếp) thông qua **Exit Interface** (cổng ra) tương ứng.
6. Nếu không tìm thấy route nào, router sẽ sử dụng Default Route (nếu có) hoặc hủy gói tin.

- **Phân biệt:**

- **Metric:** Giá trị (chi phí) mà một giao thức định tuyến (ví dụ: OSPF, EIGRP) sử dụng để xác định đường đi *tốt nhất* trong *cùng một giao thức*. (Ví dụ: hop count, bandwidth).
- **Administrative Distance (AD):** Độ "tin cậy" của *nguồn* route. Dùng để so sánh khi có *nhiều giao thức* cùng cung cấp route đến một đích. (Ví dụ: Static = 1, EIGRP = 90, OSPF = 110. Router sẽ tin Static (1) hơn).
- **Next-Hop:** Địa chỉ IP của router kế tiếp mà gói tin phải được gửi đến.

- **Xử lý 2 route trùng khớp:**

1. Ưu tiên 1: **Longest Prefix Match**. Router luôn chọn route có subnet mask dài nhất (cụ thể nhất). (Ví dụ: `192.168.1.0/25` sẽ được ưu tiên hơn `192.168.1.0/24`).
2. Ưu tiên 2 (Nếu prefix length bằng nhau): **Administrative Distance (AD)**. Router chọn route có AD thấp nhất.
3. Ưu tiên 3 (Nếu AD cũng bằng nhau): **Metric**. Router chọn route có metric thấp nhất.

11) Static Route

- Cú pháp Static Route IPv4:

`ip route [destination_network] [subnet_mask] [next_hop_ip | exit_interface]`

- Cú pháp Static Route IPv6:

`ipv6 route [destination_prefix] [next_hop_ip | exit_interface]`

- **Default Route (Gateway of Last Resort):** Là một static route đặc biệt (`0.0.0.0 0.0.0.0` cho IPv4 hoặc `::/0` cho IPv6). Đây là route được sử dụng khi router *không tìm thấy* bất kỳ route cụ thể nào khác trong bảng định tuyến cho một gói tin. Nó thường được dùng để trở ra Internet (ISP).
- **Ví dụ (Trên Router A):** Giả sử địa chỉ IP của Router B (phía kết nối với A) là `192.168.99.2`.

Cisco CLI

```
ip route 10.0.0.0 255.255.255.0 192.168.99.2
```